

Password cracking using John the ripper

* Linux stores passwords hashes in /etc/shadow, not in plaintext.

g.
msfadmin : \$1\$05byfIVL\$0P/wmvJKORISyDfN3.9M
 ↓ ↓
 username hash

* \$1\$ - means it's hashed with MD-5 crypt

\$5\$ = SHA-256

\$6\$ = SHA-512

* 05byfIVL is the salt (random data mixed in) so identical passwords don't provide identical hashes

* the rest is the hash output

Steps →

Step 1 - Gain access to target

ssh msfadmin@ <target ip>

* ssh - secure shell -
opens an encrypted remote login session to another machine.

★ msfadmin - username being logged in
(default metasploitable2 account)

next, you are prompted for password

- sudo cat /etc/shadow

★ sudo - superuser do - runs command with root privileges.

★ cat - prints the file's contents to the terminal.

★ /etc/shadow - system file storing hashed passwords + password aging meta-data.

Step2 Pull the password files from target → Kali

ssh msfadmin @ <target ip> "cat /etc/passwd" > passwd.txt.

★ > - redirection operator

★ passwd.txt - local file on Kali where output is stored.

ssh msfadmin @ <target ip> "cat /etc/passwd" > shadow.txt

pulls the actual password hashes.

★ /etc/shadow - has hashes but not full account context
/etc/passwd - has account structure but no hashes

Step 3 Merge the two files

`unshadow passwd.txt shadow.txt > mf2-hashes.txt`

* `unshadow` - combines `passwd` & `shadow` data into single line format

username : hash : UID : GID : —

`mf2-hashes.txt` - output file -

actual file we run John against

Step 4 Prepare a wordlist

`sudo gunzip -k /usr/share/wordlists/rockyou.txt.gz`

* `gunzip` - decompress .gz files

* `-k` - keep - retains the original compressed file

* `rockyou.txt.gz` - well known wordlist (14 million leaked passwords)

Step 5 Run John

activates dictionary attack mode

`john --wordlist = /home/narya/rockyou.txt`

`mf2-hashes.txt`

password
cracking
program

file to
attack

Step 6 View cracked results

john --show mf2-hashes.txt

Key terms

1. Salt - random data added before hashing to make identical passwords produce hashes.
2. hash - one way mathematical function output representing a password.